UBAYA
UNIVERSITAS SURABAYA

1604C051 – Full-stack Programming

Security

Week 06

Program Studi Teknik Informatika
Fakultas Teknik – Universitas Surabaya

Hendra Dinata

Validasi Input

Prinsipnya...

Entah websitemu dipublish secara umum atau cuma diakses secara intranet, selalu lakukan validasi terhadap input dari user

Mengapa?

- Validasi Input membantu memastikan integritas data.
- Post form mungkin tidak berasal dari client yang diharapkan atau dari aplikasi website yang sama.

Tips

1. Validasi ulang setiap data di sisi server
   Jangan percaya sepenuhnya pada HTML5 atau javascript, karena user memiliki kuasa penuh untuk melakukan perubahan terhadapnya.

   Contoh: Hati-hati terhadap fitur “Inspect Element” pada browser

   Lanjut … >>

Awalnya kamu memiliki textbox demikian, sehingga kamu berharap user tidak akan memasukkan angka kurang dari 0 dan lebih dari 4

```
<input type="number" min="0" max="4" name="txt_ipk">
```

Tetapi dengan "Inspect Element", user dapat mengubahnya menjadi demikian:

```
<input type="number" min="0" max="5" name="txt_ipk">
```

Dalam hal demikian, apakah yang akan terjadi jika user memasukkan angka 5 dan langsung kamu simpan ke dalam database?

Tips

2. Validasi tipe data

(ex: www.site.com/article.php?id=15)
id = 15 harus dikonversi lagi ke dalam bentuk integer int($_GET[‘id’]) dalam script PHP

Contoh lain

Perhatikan contoh potongan Coding untuk membuat PAGING ini:

```
// jumlah data per halaman
$per_halaman = 3;
// offset
$mulai_baris_ke = (isset($_GET['start'])) ? $_GET['start'] : 0;
$sql = "Select * From employees where FirstName like ? LIMIT ?,?";
$name = "%";
$stmt = $mysqli->prepare($sql);
$stmt->bind_param("sii", $name, $mulai_baris_ke, $per_halaman);
$stmt->execute();
```

Apakah jadinya, jika ada user mengetikkan alamat di Browser seperti ini:

http://www.domainku.com/?start=abc



Contoh lain

Akan lebih aman jika ditambahkan pengaman:

```
// jumlah data per halaman
$per_halaman = 3;
// offset
$mulai_baris_ke = (isset($_GET['start'])) ? $_GET['start'] : 0;
if( !is_numeric($mulai_baris_ke) ) $mulai_baris_ke = 0;
$sql = "Select * From employees where FirstName like ? LIMIT ?,?";
$name = "%";
$stmt = $mysqli->prepare($sql);
$stmt->bind_param("sii", $name, $mulai_baris_ke, $per_halaman);
$stmt->execute();
```

Tips

3. Sanitasi

Ada kemungkinan data yang dikirim oleh user ke server itu mengandung suatu karakter tertentu yang memberikan efek negatif terhadap database atau website.

Contoh 1

Ada suatu data yang biasa disajikan di halaman suatu website
$res = $mysqli->query(“Select * From tabelku”);
$row= $res->fetch_assoc();
echo $row[“kolomTertentu”];

Data mungkin berasal dari sebuah <form> input biasa.
Tetapi, apa jadinya jika sebelumnya user menginputkan datanya seperti ini:

Kolom Tertentu : <img src="http://websiteaneh.com/gambar_porno.jpg”>

SUBMIT

Contoh 1:

Solusi:

Gunakan htmlentities() pada setiap data sebelum dilakukan proses “INSERT”

$kolomTertentu = htmlentites($_POST[‘txtKolomTertentu’]);

Contoh 2

Ada suatu data yang biasa disajikan di halaman suatu website

```
$res = $mysqli->query(“Select * From tabelku”);
$row= $res->fetch_assoc();
echo "<input type='hidden' name='sesuatu'
value="".$row["kolomTertentu"]."'>";
```

Data mungkin berasal dari sebuah <form> input biasa.
Tetapi, apa jadinya jika sebelumnya user menginputkan datanya seperti ini:

Kolom Tertentu : He's Batman

SUBMIT

Contoh 2:

Solusi:

Gunakan htmlentities() pada setiap data sebelum dilakukan proses “INSERT”

$kolomTertentu = htmlentites($_POST[‘txtKolomTertentu’]);

Encryption

Enkripsi

- Terutama informasi yang perlu diamankan, seperti kata sandi dan nomor kartu kredit, tidak boleh disimpan dalam format yang tidak terenkripsi.

- Fungsi enkripsi satu arah harus digunakan ketika dekripsi tidak pernah diperlukan, seperti dengan kata sandi. Untuk mengonfirmasi kata sandi, misalnya, mengenkripsi inputan user dan membandingkan nilai itu dengan kata sandi terenkripsi yang disimpan di dalam sistem.

- Pernahkah Anda lupa kata sandi Anda dan kemudian Anda mengklik "Lupa Kata Sandi" yang disediakan oleh Situs Web? Apa yang anda dapatkan?
  Apakah Anda mendapatkan email dengan kata sandi biasa sebelumnya dari Situs Web?
  Jika Anda mendapatkan kata sandi sebelumnya, kata sandi Anda tidak dienkripsi oleh sistem, atau sistem menggunakan enkripsi dua arah (sistem dapat mendekripsi kata sandi Anda), dan itu tidak AMAN!

Latihan

1. Siapkan tabel users, (iduser, nama, password)
2. Buat Registration.php untuk mendaftarkan akun pengguna baru. Akan ada 4 textbox: iduser, nama pengguna yang diinginkan, kata sandi yang diinginkan, masukkan kembali kata sandi yang diinginkan
3. Ini akan menyimpan dalam tabel "users" dengan 3 kolom (iduser, nama pengguna, dan sandi)
4. Sekarang buat login.php

Latihan

Melakukan enkripsi password sebelum disimpan ke dalam tabel:

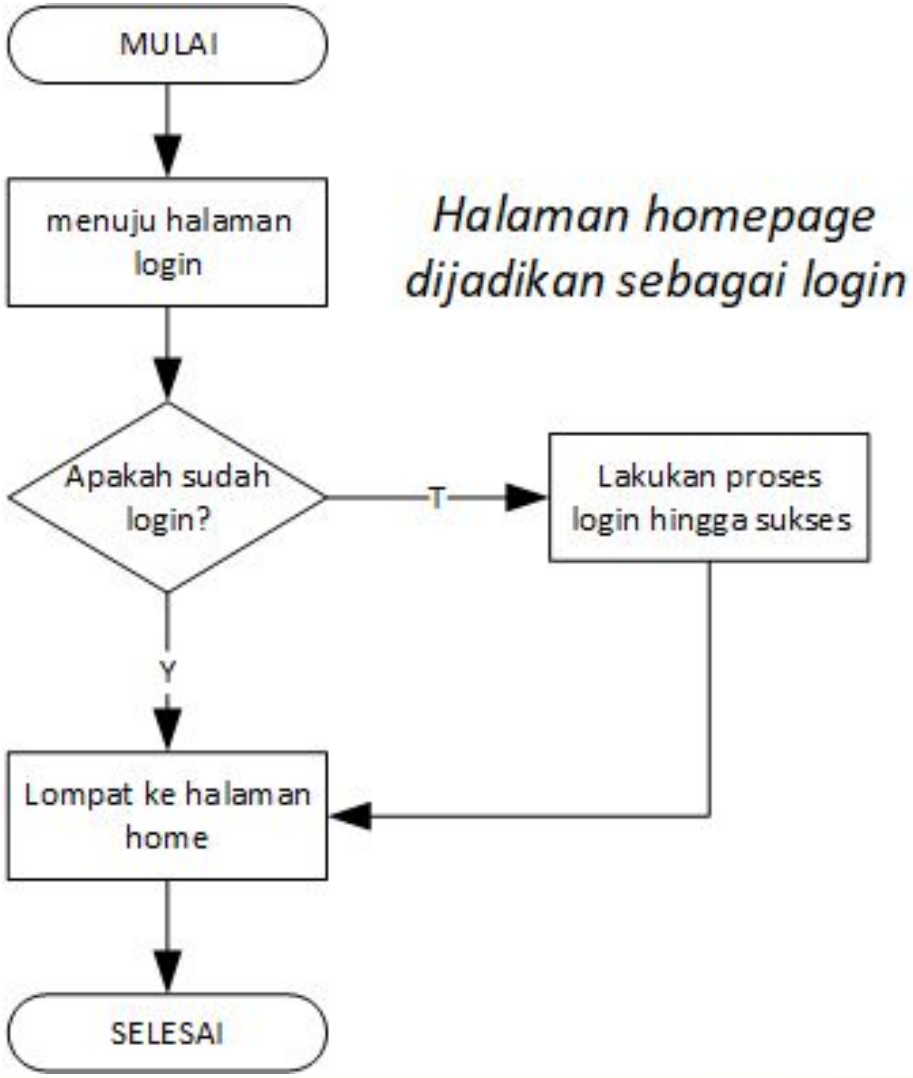
```
$hash_password = password_hash($plain_password, PASSWORD_DEFAULT);
```

Melakukan otentikasi:

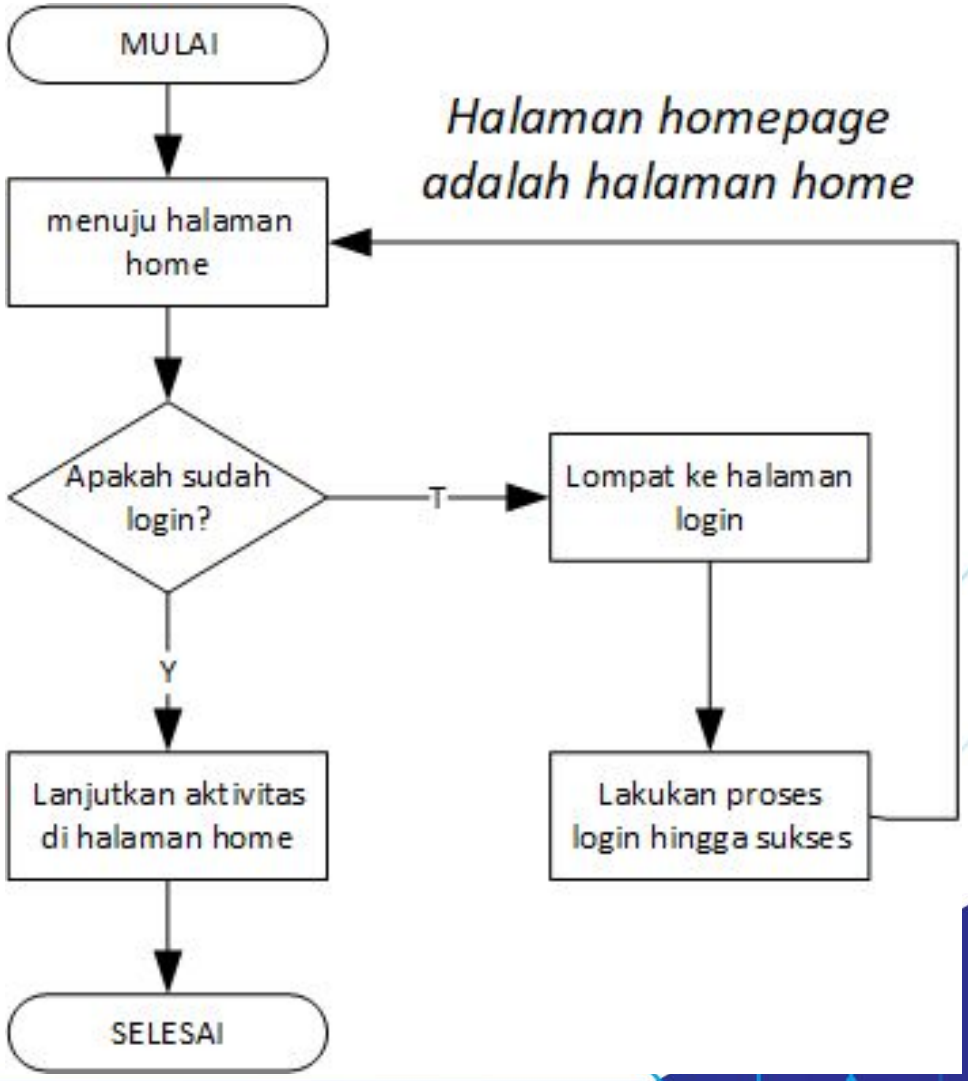
```
$is_authenticated = password_verify($plain_password, $hash_password);
```

Kenyamanan dalam Keamanan

Mana yang lebih baik?



Halaman homepage dijadikan sebagai login

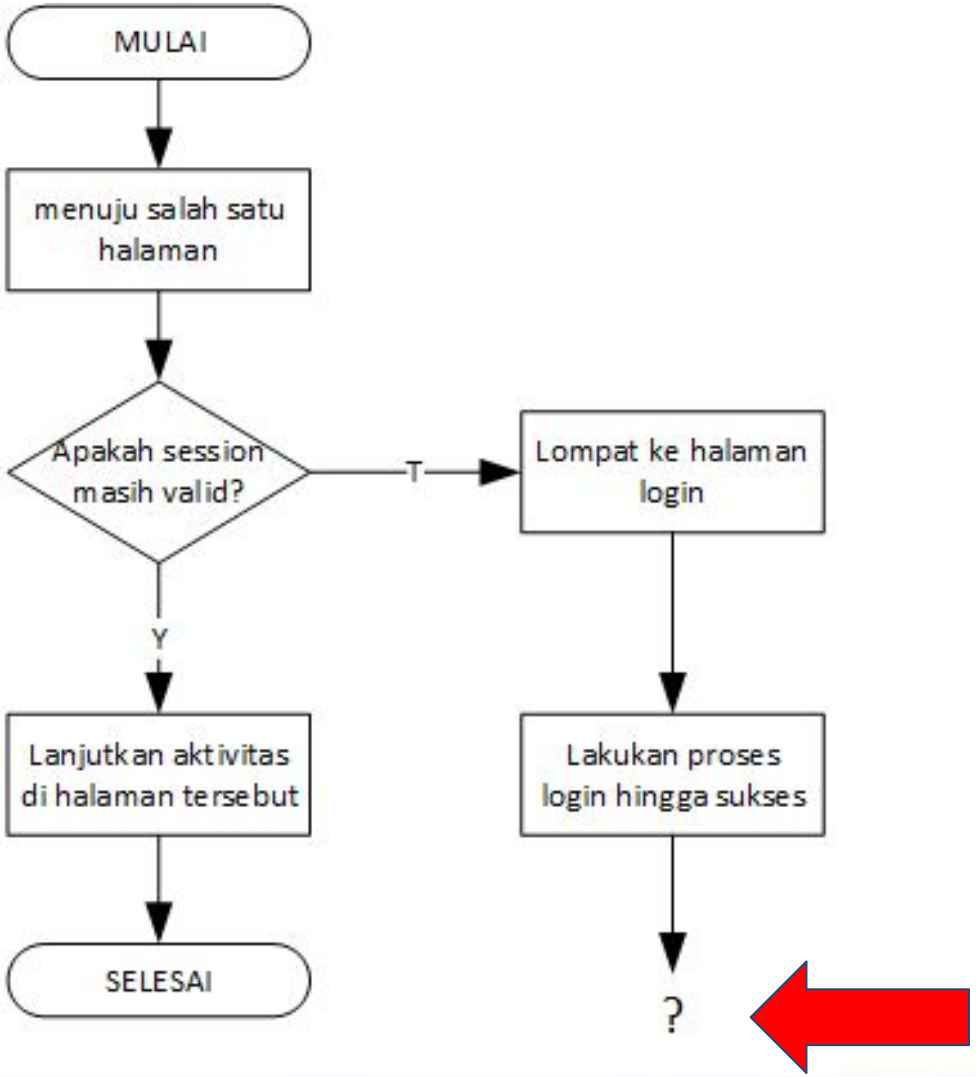


Halaman homepage adalah halaman home

Session Login Expired

Apa yang terjadi jika session login telah expired lalu user mengklik salah satu menu? User pasti akan digiring menuju halaman login untuk melakukan login ulang

Session Login Expired



Yang menjadi issue adalah :

setelah login sukses, user akan digiring ke mana?

a. ke halaman home
b. ke halaman yang tadi dituju

Session Login Expired

Contoh kasus di mana sistem akan menggiring user menuju halaman terakhir yang hendak dituju setelah “dipaksa” untuk melakukan login ulang.

Bagaimana caranya?

Contoh:

ketika user dipaksa untuk melakukan login ulang:
http://www.domainku.com/login.php?urlnya=http://www.domainku.com/halamantertentu.php

Mendapatkan current url

Alternatif 1:

```
// find out the domain:
$domain = $_SERVER['HTTP_HOST'];
// find out the path to the current file:
$path = $_SERVER['SCRIPT_NAME'];
// find out the QueryString:
$queryString = $_SERVER['QUERY_STRING'];
// put it all together:
$url = "http://" . $domain . $path . "?" . $queryString;
echo $url;
```

Mendapatkan current url

Alternatif 2:

```
// An alternative way is to use REQUEST_URI instead of both
$uri = $_SERVER['REQUEST_URI'];
// SCRIPT_NAME and QUERY_STRING, if you don't need them seperate:
$url = "http://" . $domain . $uri;
echo $url;
```